

Hardening Email Sender Authentication: Reproducing SPF/DKIM/DMARC Misconfiguration Attacks

Guilherme Ferreira
up201706719@fe.up.pt

João Oliveira
up202205302@fe.up.pt

Ayrton da Cruz
up...@fe.up.pt

Ana Lúcia Ferreira
up....@fe.up.pt

Abstract

This project focuses on email sender authentication mechanisms (SPF, DKIM, and DMARC) and how real-world misconfigurations enable spoofed messages that appear to originate from trusted domains, despite these mechanisms being deployed. Misconfigured or missing DNS records leave organizations exposed to phishing and impersonation attacks, and are concrete instances of OWASP Security Misconfiguration and Identification and Authentication Failures in the email ecosystem.

Our main goal is to build a controlled lab environment with several test domains and mail servers (e.g., Postfix/Dovecot) using deliberately weak or inconsistent SPF, DKIM, and DMARC policies. We will reproduce a subset of spoofing attacks documented in the literature and in bug-bounty writeups, using tools such as swaks, Espoofer, and custom Python scripts to generate and analyze spoofed messages under different configurations. Network captures and server logs will be used to characterize how various policies affect deliverability and message authentication results.

Based on these experiments, we will propose and evaluate hardening guidelines and simple MTA-side checks that enforce safer interpretations of authentication results and stricter alignment between DNS records and actual senders. The expected outcome is an implementation and demonstration of a proof-of-concept lab that (i) shows successful spoofing under realistic misconfigurations and (ii) demonstrates how our proposed configurations and filters prevent the same attacks, potentially serving as the basis for a SEED-style lab in future editions of the course.

I. Introduction

Email remains a primary vector for phishing and social-engineering attacks, and many of these campaigns succeed by forging messages that appear to come from trusted internal or partner domains. Standards such as SPF, DKIM, and DMARC were designed to authenticate email senders and detect spoofed messages, but in practice they are often deployed with weak or inconsistent policies that still allow successful impersonation.

In this project, we target the concrete problem of sender spoofing enabled by misconfigured SPF/DKIM/DMARC records. Our approach is to reproduce such misconfigurations in a controlled lab environment, demonstrate how an attacker can exploit them to bypass sender authentication, and then design and evaluate practical hardening measures at the DNS and MTA levels. This aligns with the course goal of understanding vulnerabilities, building realistic attack scenarios, and proposing and testing defenses on a concrete service.

II. Related work

Chen et al. provide a detailed case study of email sender authentication in the wild, showing how inconsistencies in the way SPF, DKIM, and DMARC are combined across servers and clients enable 18 practical evasion techniques and even the forging of DKIM-signed messages [1]. Their work strongly motivates our focus on composition issues and misconfigurations rather than on the cryptographic primitives themselves.

Operational blogs and deployment guides further document common SPF, DKIM, and DMARC setup mistakes and their impact on spoofing and phishing risk, highlighting how often domains deploy these mechanisms with weak or inconsistent policies [2], [3]. On the tooling side, Espoofer is an open-source email spoofing testing tool that systematizes many of the attacks identified in the literature and in practice, and provides a useful starting point for constructing and automating spoofing experiments in a controlled environment [4]. We will also frame our work using the OWASP Top 10:2025 categories A02:2025 Security Misconfiguration and A07:2025 Authentication Failures, since misconfigured or missing sender-authentication records are a concrete example of these broader classes of vulnerabilities in the email ecosystem [5], [6].

References

- [1] J. Chen, V. Paxson, and J. Jiang, “Composition kills: A case study of email sender authentication,” in Proceedings of the 29th USENIX Security Symposium (USENIX Security 2020), 2020, pp. 2183–2199. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity20/presentation/chen-jianjun>
- [2] Infraforge, “Spf, dkim, dmarc: Common setup mistakes,” <https://www.infraforge.ai/blog/spf-dkim-dmarc-common-setup-mistakes>, 2026, accessed: 2026-03-16.
- [3] DMARCLY, “How to implement dmarc/dkim/spf to stop email spoofing/phishing: The definitive guide,” <https://dmarcly.com/blog/how-to-implement-dmarc-dkim-spf-to-stop-email-spoofing-phishing-the-definitive-guide>, 2024, accessed: 2026-03-16.
- [4] J. Chen, “Espoofer: An email spoofing testing tool,” <https://github.com/chenjj/espoofer>, accessed: 2026-03-16.
- [5] OWASP Foundation, “A02:2025 – security misconfiguration,” https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/, 2025, accessed: 2026-03-16.
- [6] —, “A07:2025 – authentication failures,” https://owasp.org/Top10/2025/A07_2025-Authentication_Failures/, 2025, accessed: 2026-03-16.